08. - Ataques Wi-Fi - PSK (Pre Shared Key)

Introducción

PSK (Pre Shared Key)

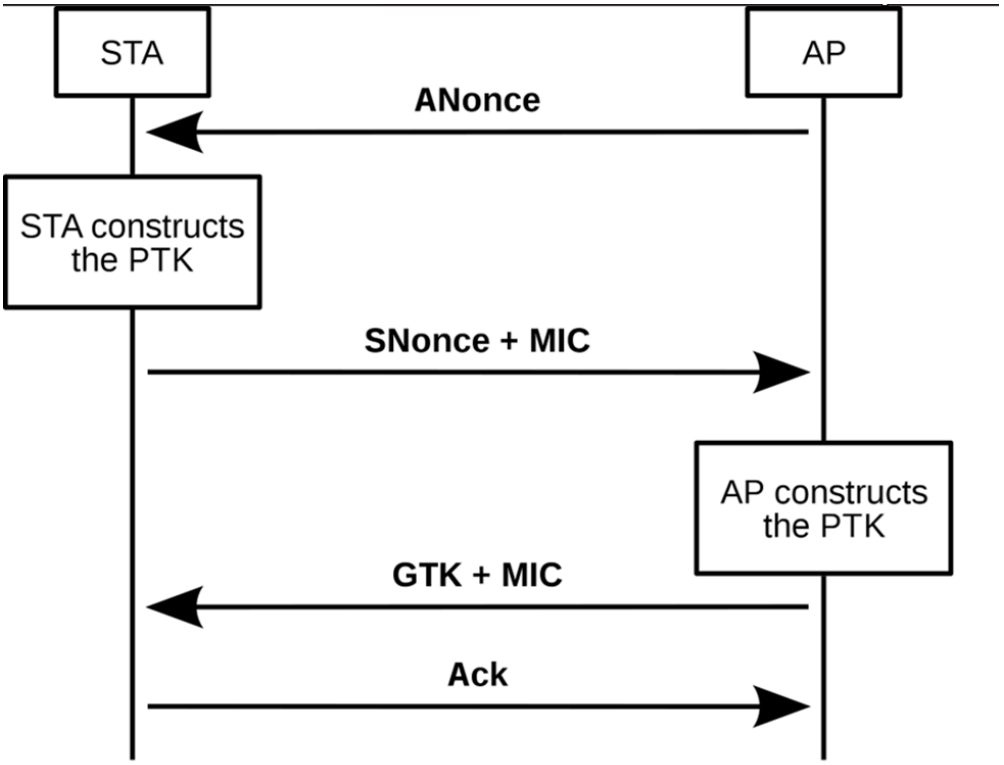
El método PSK o de Clave Precompartida (en inglés, Pre Shared Key) para redes Wi-Fi es el más utilizado a nivel mundial. Este método requiere que los usuarios introduzcan una contraseña compartida antes de poder conectarse. Este tipo de redes actualmente suelen ser tan seguras contra ataques directos como lo sea su contraseña, por lo que si la contraseña es compleja y no está en ningún diccionario ni con variaciones y no utiliza ningún algoritmo de generación predecible es prácticamente imposible de atacar directamente. Pero, como vamos a ver a continuación, esto no es así si el AP utiliza WPS con una configuración incorrecta, tiene versiones antiguas con vulnerabilidades o es posible engañar a los usuarios con un Evil Twin para obtener la contraseña en texto claro.

Ataques Wi-Fi - PSK (Pre Shared Key)

Handshakes

Teoría

El Handshake, también conocido como apretón de manos, es un proceso de autenticación utilizado en redes Wi-Fi protegidas con WPA/WPA2-PSK. Este proceso asegura que tanto el cliente como el punto de acceso poseen la clave precompartida correcta sin transmitirla realmente por el aire. Un ataque contra el Handshake captura este intercambio para intentar descifrar la contraseña de la red mediante técnicas de fuerza bruta o diccionario. A continuación, podemos ver cómo funciona el proceso de Handshake entre un cliente y el AP.



Funcionamiento Handshake en PSK

- **Mensaje 1: Iniciación por el AP.** El punto de acceso (AP) envía un frame EAPOL-Key al cliente. Este frame incluye un nonce generado aleatoriamente (ANonce), que se utiliza en el proceso de generación de claves.
- **Mensaje 2: Respuesta del Cliente.** El cliente responde con su propio frame EAPOL-Key. Este frame incluye otro nonce (SNonce) y un Código de Integridad del Mensaje (MIC) para asegurar la integridad de los datos. El cliente utiliza el ANonce, el SNonce y la clave precompartida (PSK) para calcular la Clave Transitoria de Pareja (PTK). Por lo que este mensaje está cifrado con la clave PSK. Por lo que únicamente es necesario el mensaje 1 y 2 para crackear la contraseña.
- **Mensaje 3: AP Envía**GTK. El AP envía otro frame EAPOL-Key al cliente. Este frame contiene la Clave Temporal de Grupo (GTK) cifrada con la PTK, junto con un MIC. El AP también calcula la PTK para asegurarse de que ambas partes tengan claves coincidentes.
- **Mensaje 4: Acknowledgment del Cliente.** El cliente envía un último frame EAPOL-Key al AP. Este frame sirve como reconocimiento de que el cliente ha recibido con éxito la GTK y que tanto el cliente como el AP han derivado la misma PTK.

Ataque

Este ataque consiste en obtener el Handshake monitorizando cuando un cliente se conecta y realizar fuerza bruta localmente sobre esos paquetes para obtener la PSK que genera ese Handshake. Un dato importante sobre el ataque a los Handshake es que solo es necesario obtener el Mensaje 1 y el mensaje 2 para poder realizar el ataque de fuerza bruta.

Para explotar este ataque en Linux, primero se configura la interfaz de red en modo monitor.

```
sudo airmon-ng start wlan0
```

Después, se utiliza airodump-ng para capturar el Handshake entre el punto de acceso y el cliente.

```
sudo airodump-ng wlan0mon -c <CANAL> -w ~/wifi/capture
```

Se puede esperar a que un cliente se conecte para hacer el ataque 100% pasivo, o se pueden enviar paquetes de desautenticación con aireplay-ng para forzar la reconexión del cliente y capturar el Handshake.

```
sudo aireplay-ng -0 10 -a <BSSID> -c <ClientMAC> wlan0mon
```

Una vez capturado el Handshake, puede utilizarse aircrack-ng junto con un diccionario para intentar descifrar la contraseña.

```
sudo aircrack-ng -w /ruta/a/diccionario.txt capture-01.cap
```

aircrack-ng solo crackea utilizando CPU, por lo que no es la mejor opción para la vida real, ya que es realmente lento comparado con la velocidad de las tarjetas gráficas (GPU). Para utilizar toda la potencia de la GPU se utiliza hashcat. Para esto hay que exportar el handshake para esta herramienta desde el .cap. Este proceso puede ser lioso ya que hay varios tipos de modos que soporta hashcat. Actualmente hashcat ha cambiado como se crackea un handshake, siendo el modo actual 22000, por lo que hay que exportar para este formato en las últimas versiones, ya que la versión anterior (2500) ya no existe. La última versión que mantiene las 2 opciones es la 6.0.0 (que es la versión que se encuentra en el Lab a partir de la versión v2.0.4).

Exportamos el Handshake a modo 22000 y crackeamos.

```
hcxpcapngtool aux.pcap -o hash.22000
sudo hashcat -a 0 -m 22000 hash.22000 ~/rockyou.tx
```

Esto se puede realizar en el laboratorio en la mayoría de los equipos añadiendo el parámetro --force para que continue a pesar de los errores, pero no en todos los equipos funciona ya que hashcat no está preparado para trabajar en VM demasiado bien. También se puede utilizar el parámetro -D seguido de un 1 para forzar CPU y un 2 para forzar GPU, por lo que se puede utilizar -D 2,1 --force. Por lo que también se puede copiar el fichero hash.22000 y copiarlo fuera de la VM para crackearlo. hashcat se puede descargar de su ya listo para funcionar tanto en Windows como en Linux, en Windows si hay tarjeta gráfica con los drivers instalados funciona muy bien. Para descargar directamente la versión 6.0.0 puedes descargar

El antiguo para Handshake es el número 2500, que se puede crackear de la siguiente manera:

```
hashcat -m 2500 capture.hccapx /ruta/a/diccionario.txt
```

En el caso de tener un hash en formato 2500, es posible convertir 2500 a 22000, para eso hay que seguir los siguientes pasos.

1. Convertir el hccapx de 2500 a pcap

```
hcxhash2cap --hccapx=hostapd.hccapx -c aux.pcap
```

2. Exportar el handshake en formato 22000 del pcap

```
hcxpcapngtool aux.pcap -o hash.22000
```

3. crackear el hash con hashcat en formato 22000

Este ataque es posible incluso con una sola interfaz levantando el AP con hostapd y monitorizando el tráfico de dicha interfaz con tshark o wireshark.

PMKID

El ataque **PMKID** explota una vulnerabilidad en la implementación de WPA/WPA2-PSK en algunos routers, que permite capturar el PMKID (Pairwise Master Key Identifier) para derivar la contraseña sin necesidad de capturar el proceso de Handshake completo. La vulnerabilidad se presenta principalmente en dispositivos que tienen configurado 802.11r (Fast BSS Transition) o en aquellos que están mal configurados, ya que el PMKID puede ser solicitado directamente al punto de acceso (AP) durante el proceso de reautenticación. Una vez capturado el PMKID, los atacantes pueden usar herramientas de fuerza bruta para intentar descifrar la contraseña de la red, exponiendo así la seguridad de esta. Este ataque es cada vez menos común, pero si los APs son vulnerables permiten realizar un ataque sin que haya ningún cliente conectado a la red, por lo que se llama a este ataque clientless

Para realizar este ataque, primero se coloca la interfaz de red en modo monitor.

```
sudo airmon-ng start wlan0
```

Para capturar el PMKID utilizando hcxdumptool, usamos el siguiente comando:

```
sudo hcxdumptool -i wlan0mon -o capture.pcapng --enable_status=1
```

El archivo capturado se convierte a un formato compatible con hashcat usando hcxpcapngtool. Debemos seleccionar el formato 22000 para hashcat 6:

```
sudo hcxpcapngtool -o capture.22000 capture.pcapng
```

Finalmente, se intenta descifrar el PMKID para obtener la clave PSK con hashcat:

```
sudo hashcat -m 22000 -a 0 capture.22000 /ruta/a/diccionario.txt
```

Existen herramientas avanzadas como airgeddon, que facilitan el proceso de captura de handshakes y PMKID al automatizar gran parte de las tareas necesarias para estas acciones de seguridad en redes. Además, el paquete aircrack-ng ofrece la capacidad de analizar archivos de captura (.cap) para verificar si contienen un handshake o un PMKID, lo cual es particularmente útil para validar la efectividad de la captura antes de avanzar en el proceso de descifrado.

PMKID en cap detectada aircrack-ng

NoAP

Teoría noAP

El ataque NoAP, también conocido como half-handshake o medio-handshake, es una técnica utilizada por los atacantes para engañar a los clientes haciéndoles creer que están conectándose a un punto de acceso legítimo cuando en realidad están conectados a un dispositivo malicioso. Este tipo de ataque se basa en la suplantación de identidad del AP. Este ataque se basa en crear una red basándose en los probes de los clientes.

El PNL (Preferred Network List) es una lista de redes conocidas y preferidas que el dispositivo almacena y utiliza para decidir automáticamente a cuál red conectarse, basándose en factores como la prioridad de la red y la disponibilidad de la señal, esto ocurre cuando un cliente tiene habilitada la opción de conectarse automáticamente en los dispositivos. Los dispositivos almacenan tanto el ESSID como el tipo de seguridad y su clave, pero no almacenan ni el BSSID ni ningún otro tipo de información que identifique al AP.

Los probe requests pueden ser aprovechados por atacantes en ataques de suplantación (como un Evil Twin) para hacer que los dispositivos se conecten a puntos de acceso falsos. En el caso de ser redes abiertas los clientes se conectarían directamente, en este caso, al ser una PSK, durante el Handshake es necesario que ambas partes tengan la PSK, es decir, la contraseña de la red, para una conexión completa con el AP y poder monitorizar y atacar el cliente en la red del atacante. En el caso de no conocer la contraseña se puede realizar un ataque de noAP para obtener la contraseña ya que solo es necesario los 2 primeros paquetes del Handshake para poder realizar la fuerza bruta, y como hemos visto antes, el mensaje 1 lo manda el AP sin utilizar la clave para ello, siendo el mensaje 2 la respuesta del cliente ya cifrado con la contraseña. Por lo que podemos crear un AP malicioso con el nombre de una red a la que un cliente se conecta automáticamente con una contraseña cualquiera y obtener el Handshake para crackearlo igual que en el ataque de Handshake.

Ataque noAP

Este ataque se puede hacer de diferentes maneras, el proceso más simple es montar un AP con el mismo nombre y una contraseña al azar y monitorizar con airodump-ng el canal del AP esperando a que un cliente intente iniciar sesión y obtener el Handshake. Este AP falso se podría crear con cualquier dispositivo, incluso con un móvil cercano o el propio AP de Windows. Pero A continuación, vamos a crearlo manualmente para hostapd.

Creamos un fichero de configuración para hostapd llamado hostapd.conf modificando las variables $INTERFACE por la interfaz Wi-Fi que se quiera utilizar (wlan0 por ejemplo) y $ESSID por el nombre de la red que hayamos detectado en los probes. En la contraseña podemos poner lo que queramos, siempre que tenga más de 8 caracteres que es el mínimo de las redes PSK y menos de 63.

```
interface=$INTERFACE
driver=nl80211
hw_mode=g
channel=6
ssid=$ESSID
wpa=2
wpa_key_mgmt=WPA-PSK
wpa_pairwise=TKIP CCMP
wpa_passphrase=12345678
```

Antes de crear el AP podemos empezar a monitorizar el tráfico Wi-Fi en el canal donde vamos a crear el AP, en este caso el 6. Para ello utilizamos airodump-ng como siempre, guardando la captura.

```
sudo airodump-ng wlan0mon -c 6 -w ~/wifi/capturec6
```

Una vez estamos monitorizando levantamos el AP con hostapd.

```
hostapd hostapd.conf
```

Una vez que obtengamos un handshake ya podemos parar el hostapd con CTRL+C, ya que los clientes van a intentar conectarse múltiples veces seguidas. Y el siguiente paso es exactamente el mismo que en el ataque de Handshake normal para PSK.

Este proceso se puede automatizar con una sola interfaz de forma más sencilla con hostapd-mana. Para esto tenemos que crear un fichero de configuración para hostapd igual pero añadiendo la línea mana_wpaout=hostapd.hccapx como se puede ver a continuación.

```
interface=$INTERFACE
driver=nl80211
hw_mode=g
channel=1
ssid=$ESSID
mana_wpaout=hostapd.hccapx
wpa=2
wpa_key_mgmt=WPA-PSK
wpa_pairwise=TKIP CCMP
wpa_passphrase=12345678
```

Reemplazamos las variables igual que antes y ejecutamos hostapd-mana.

```
hostapd-mana hostapd.conf
```

Una vez que capturemos un Handshake, aparecerá una línea con el mensaje MANA: Captured a WPA/2 Handshake from: XX:XX:XX:XX:XX. En ese momento, podemos detener el programa presionando CTRL+C, ya que si lo dejamos ejecutándose, se seguirán capturando múltiples Handshakes con la misma contraseña pero con diferentes hashes y Salt. Esto hará que el proceso de fuerza bruta sea más lento, ya que el programa intentará descifrar cada uno de ellos.

El único problema de este proceso es que nos devuelve el Handshake en formato 2500 para hashcat, por lo que necesitamos una versión vieja para realizar la fuerza bruta o seguir los pasos explicados en el apartado del ataque al Handshake para convertirlo a 22000.

> **Note**
>
> En la última versión de hostapd-mana han arreglado este fallo y se guarda el hash en formato 22000, por lo que no es necesario convertirlo y se puede crackear directamente. (Se actualizará en la siguiente versión del lab)

WPS Pin

El WPS PIN **(Wi-Fi Protected Setup Personal Identification Number)**es un método de configuración que facilita la conexión de dispositivos a una red Wi-Fi segura mediante un código de 8 dígitos. Esto permite a un cliente conectarse únicamente introduciendo el Pin de 8 dígitos en vez de la contraseña real y compleja de la red.

El WPS (Wi-Fi Protected Setup) es un método de simplificación de configuración de redes WPA/WPA2-PSK que presenta vulnerabilidades que permiten a un atacante obtener la clave precompartida en un tiempo relativamente corto, explotando el PIN WPS de 8 dígitos. Es importante tener en cuenta que no todos los APs que soportan WPS son vulnerables a este ataque, ya que pueden tener WPS por pulsación de botón (PBC, Push Button Connect), que si no tenemos acceso físico al AP no podemos hacer nada o Pin virtual, que es un pin que se genera solo durante unos segundos al activarse y después ya ningún pin es válido.

En el caso de que el AP sea claramente antiguo y utilice WPS con Pin y no bloquee el protocolo por fuerza bruta podemos realizar diferentes ataques. Existen bases de datos de PIN conocidos para modelos específicos de routers que permiten a los atacantes reducir significativamente el tiempo necesario para acceder a la red. Herramientas como airgeddon incluyen

bases de datos completas de estos PIN conocidos, lo que hace aún más sencillo intentar acceder a redes protegidas mediante WPS.

Para realizar este ataque con reaver se coloca la interfaz de red en modo monitor:

```
sudo airmon-ng start wlan0
```

Se identifican los puntos de acceso con WPS habilitado utilizando wash o con airodump-ng con la flag --wps.

```
sudo wash -i wlan0mon
```

Finalmente, se ejecuta reaver para obtener el PIN WPS y la clave PSK.

```
sudo reaver -i wlan0mon -b <BSSID> -vv
```

> **Note**
>
> Este ataque es importante tenerlo en cuenta para APs antiguos, pero hoy en día en la mayoría de las redes tanto corporativas como domésticas ya no es vulnerable.

Entre las herramientas más populares para realizar ataques WPS están reaver y bully, ambas diseñadas para aprovechar las debilidades del WPS PIN. Estas herramientas son similares en su funcionamiento y uso, permitiendo realizar ataques de fuerza bruta contra el WPS PIN. Sin embargo, reaver ha continuado evolucionando con nuevos métodos de ataque, como el ataque de PIN nulo, que no está disponible en bully. Además, airgeddon también permite lanzar estos ataques de manera sencilla, integrando reaver y bully para ofrecer una plataforma versátil desde la que ejecutar diferentes métodos y pruebas de intrusión en redes WPA.

KRACK attack

El KRACK attack **(Key Reinstallation Attack)** explota una vulnerabilidad en el proceso de Handshake de WPA2-PSK. Permite reinstalar una clave en uso, pudiendo descifrar y manipular el tráfico entre el cliente y el punto de acceso. Esta vulnerabilidad está parcheada en la mayoría de los dispositivos hoy en día y cuando es vulnerable es complicado de explotar, por lo que no se encuentra en el laboratorio y es muy complejo de encontrar en la vida real.

Para realizar este ataque, hay un repositorio de las herramientas KRACK creado por vanhoefm. A continuación, se puede ver cómo se puede descargar y compilar el proyecto.

```
sudo apt update
sudo apt install libnl-3-dev libnl-genl-3-dev pkg-config libssl-dev net-tools git sysfsutils python3-venv iw
git clone https://github.com/vanhoefm/krackattacks-scripts.git
cd krackattacks-scripts/krackattack
./build.sh
./pysetup.sh
```

Para más información sobre estas vulnerabilidades, véase https://www.krackattacks.com/

FragAttacks

Los FragAttacks **(Fragmentation Aggregation Attacks)** son vulnerabilidades en dispositivos Wi-Fi que pueden ser explotadas para fragmentar o agregar paquetes maliciosos en una red WPA/WPA2-PSK, permitiendo la inyección de paquetes maliciosos o el descifrado de datos.

Para realizar este ataque, se clona el repositorio de las herramientas de FragAttacks.

```
git clone https://github.com/vanhoefm/fragattacks.git
```

Para más información sobre estas vulnerabilidades, véase .

Este apartado se ampliará próximamente

Evil Twin y MiTM

El ataque Evil Twin consiste en crear un punto de acceso falso que imita la red WPA/WPA2-PSK original para engañar a las víctimas y hacer que se conecten. Luego, un ataque MiTM **(Man-in-the-Middle)** intercepta y manipula el tráfico redirigido. Para esto necesitamos conocer la clave real del AP para que los clientes se conecten automáticamente a nosotros siendo indistinguible el AP falso del resto de cara al cliente. En el caso de no tener la clave podemos crear un Evil Twin sin credenciales en OPN y esperar a que los clientes se conecten manualmente.

Para realizar este ataque, vamos a utilizar hostapd y dnsmasq para crear el punto de acceso falso y gestionar el servidor DHCP, respectivamente. A continuación, se muestra cómo configurar y personalizar estos servicios utilizando variables para que el usuario pueda modificar fácilmente el ESSID y otras configuraciones.

Primero, creamos un archivo de configuración para hostapd llamado hostapd.conf con el siguiente contenido:

```
interface=$INTERFACE
driver=nl80211
ssid=$SSID
hw_mode=g
channel=$CHANNEL
auth_algs=1
wpa=3
wpa_passphrase=$WPA_PASSPHRASE
wpa_key_mgmt=WPA-PSK
wpa_pairwise=TKIP
rsn_pairwise=CCMP
```

- interface=$INTERFACE: Define la interfaz de red que se utilizará para crear la red Wi-Fi. Esta variable debería ser reemplazada por el nombre específico de la interfaz (por ejemplo, wlan0).
- driver=nl80211: Especifica el controlador que se usará para manejar la interfaz Wi-Fi. nl80211 es un controlador comúnmente usado en sistemas Linux.
- ssid=$SSID: Define el nombre de la red inalámbrica (SSID). Este nombre es el que verán los usuarios cuando busquen redes Wi-Fi disponibles. La variable $SSID debe ser sustituida por el nombre que desees para tu red.
- hw_mode=g: Establece el modo de hardware. En este caso, g indica que la red funcionará en el modo 802.11g, que opera en la banda de 2.4 GHz.
- channel=$CHANNEL: Especifica el canal en el que la red operará. El valor de $CHANNEL debe ser un número entre 1 y 13, dependiendo del canal que se quiera utilizar.
- auth_algs=1: Configura los algoritmos de autenticación. El valor 1 indica que se utilizará el algoritmo de autenticación estándar.
- wpa=3: Define el protocolo de seguridad WPA a utilizar. El valor 3 indica que se permite el uso de WPA y WPA2.
- wpa_passphrase=$WPA_PASSPHRASE: Establece la contraseña de la red Wi-Fi. La variable $WPA_PASSPHRASE debe ser reemplazada por la contraseña que desees usar.
- wpa_key_mgmt=WPA-PSK: Indica que la gestión de la clave WPA se realizará mediante un sistema precompartido (PSK).

- wpa_pairwise=TKIP: Define el protocolo de cifrado que se utilizará para WPA. En este caso, se está utilizando TKIP **(Temporal Key Integrity Protocol)**.
- rsn_pairwise=CCMP: Establece el protocolo de cifrado que se usará para WPA2. CCMP se refiere a Counter Mode Cipher Block Chaining Message Authentication Code Protocol (Counter Mode CBC-MAC Protocol), que es más seguro que TKIP.

Explicación de las variables:

- INTERFACE: La interfaz de red específica que se usará, como por ejemplo wlan0.
- SSID: El nombre de la red Wi-Fi que será visible para otros dispositivos.
- CHANNEL: El canal de frecuencia en el que operará la red Wi-Fi.
- WPA_PASSPHRASE: La clave de seguridad que deben usar los dispositivos para conectarse a la red Wi-Fi.

Una vez tenemos el hostapd configurado podemos configurar dnsmasq para que actúe como servidor DHCP y DNS. Para eso creamos un archivo llamado DNSmasq.conf con el siguiente contenido:

```
interface=$INTERFACE
dhcp-range=192.168.2.2,192.168.2.100,12h
dhcp-option=3,192.168.2.1
dhcp-option=6,192.168.2.1
server=8.8.8.8
log-queries
log-dhcp
```

- GATEWAY_IP: Puerta de enlace predeterminada para los dispositivos conectados. Interfaz con el AP de hostapd.

Iniciamos dnsmasq con el siguiente comando:

```
sudo DNSmasq -C DNSmasq.conf
```

A continuación, ajustamos las reglas de iptables para redirigir el tráfico a través de nuestro eth0 (o cualquier otra interfaz con acceso a Internet):

```
sudo iptables --table nat --append POSTROUTING --out-interface eth0 -j MASQUERADE
sudo iptables --append FORWARD --in-interface $INTERFACE -j ACCEPT
```

Habilitamos el reenvío de paquetes para el MiTM:

```
sudo sysctl -w net.ipv4.ip_forward=1
```

Finalmente, utilizamos ettercap u otra herramienta de interceptación de tráfico para llevar a cabo el ataque de MiTM:

```
sudo ettercap -T -q -i $INTERFACE
```

Una vez tenemos todo esto listo podemos iniciar hostapd para levantar el AP y comenzar el ataque:

```
sudo hostapd hostapd.conf
```

Evil Twin OPN y portal cautivo

Un atacante podría intentar realizar ataques contra los clientes de la red actuales o futuros creando un AP falso con el mismo nombre pero sin ser PSK, siendo una red OPN. La versión más clásica de este ataque se realiza creando un AP falso con el mismo nombre y levantando un portal cautivo al conectarse un cliente pidiendo las credenciales de la red PSK.

Esto se puede realizar con herramientas como airgeddon, que además de automatizar todo el proceso también verifica utilizando un handshake que la contraseña del usuario es válida, indicándole que la contraseña es incorrecta en la web del portal cautivo si la contraseña no es la correcta.

Descifrado

El **descifrado** implica recuperar la información original de los datos cifrados. En el contexto de WPA/WPA2-PSK, esto significa descifrar tráfico capturado a partir de los handshakes obtenidos conociendo la clave PSK de la red. Esto ocurre ya que en el Handshake se negocian las claves de cifrado que va a utilizar el cliente y el AP para cifrar el resto de los paquetes, por lo que si tenemos los 4 paquetes del Handshake, podemos descifrar esa comunicación y obtener las claves para descifrar todo el tráfico posterior. Estas claves cambian con el tiempo, pero mientras estemos monitorizando el tráfico posterior al handshake y no perdamos los paquetes de renegociación de claves podremos descifrar todo el tráfico Wi-Fi de ese usuario. Esto permite ver la información sin el cifrado de PSK, al mismo nivel que en redes OPN, por lo que si el cliente utiliza una VPN o utiliza comunicaciones cifradas no podremos ver el tráfico real del cliente, pero normalmente se puede obtener bastante información, sobre todo si la red PSK tiene acceso a servicios corporativos internos que normalmente no están cifrados, como muchas webs internas o LDAP sin TLS.

Para realizar este ataque, se captura el tráfico utilizando tshark o airodump-ng. En este proceso yo recomiendo siempre realizar ataque de deauth a todos los clientes para obtener los handshakes de todos los usuarios, de este modo podemos descifrar el tráfico de todos los usuarios. Para esto podemos realizar un ataque de deauth con aireplay-ng a todos los clientes o ir uno por uno o utilizar UnicastDeauth (https://github.com/mamatb/UnicastDeauth) para automatizar este proceso.

```
UnicastDeauth.py -i wlan0 -e $ESSID -b
```

Descifrado con airdecap-ng

Una vez tenemos los handshakes y hemos obtenido la contraseña de la red podemos descifrar tráfico utilizando airdecap-ng:

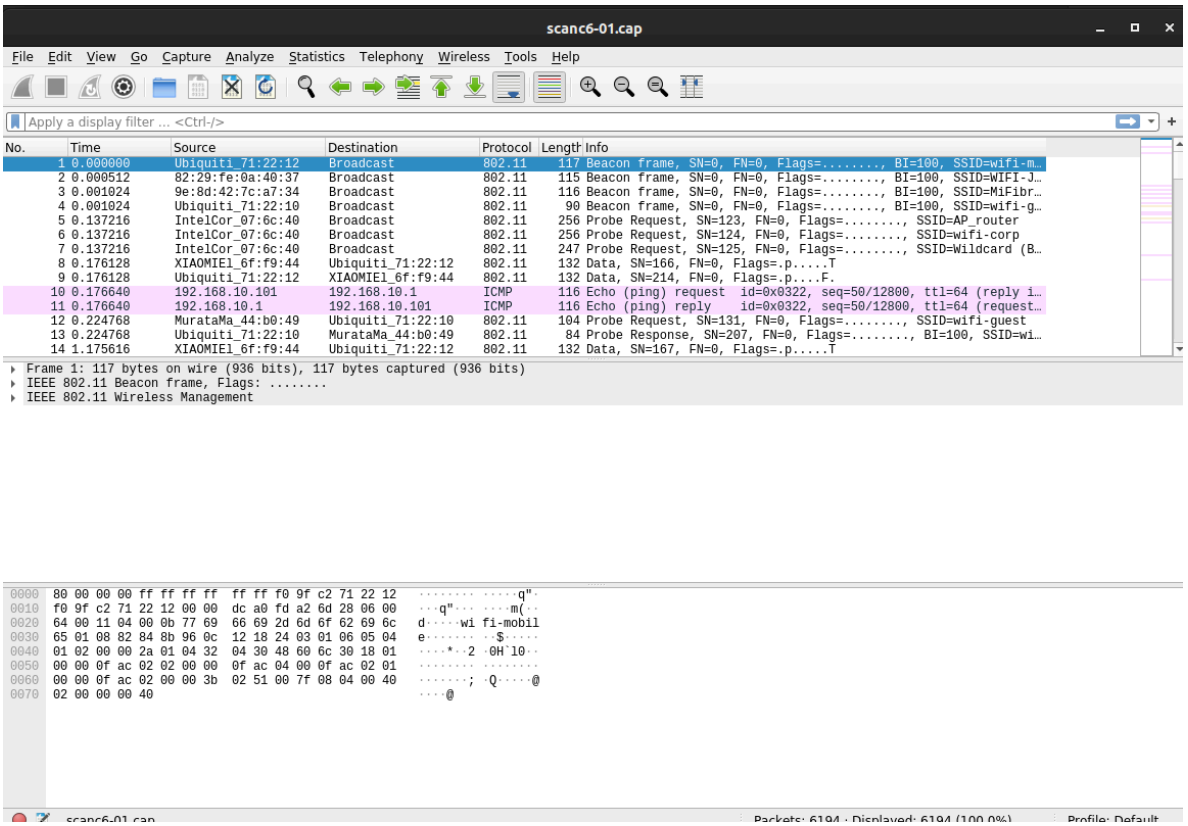
```
airdecap-ng -e $ESSID -p $PASSWORD ~/wifi/scanc6-01.cap
```

Esto genera un fichero con el mismo nombre que el original pero acabado en -dec, en el ejemplo sería ~/wifi/scanc6-01-dec.cap. Este fichero ya podemos abrirlo con Wireshark y ver todo el tráfico descifrado. En este fichero solo se encuentra la información descifrada, por lo que si en la captura original había información de redes OPN sin cifrar no se guarda en este nuevo fichero.

Descifrado con Wireshark

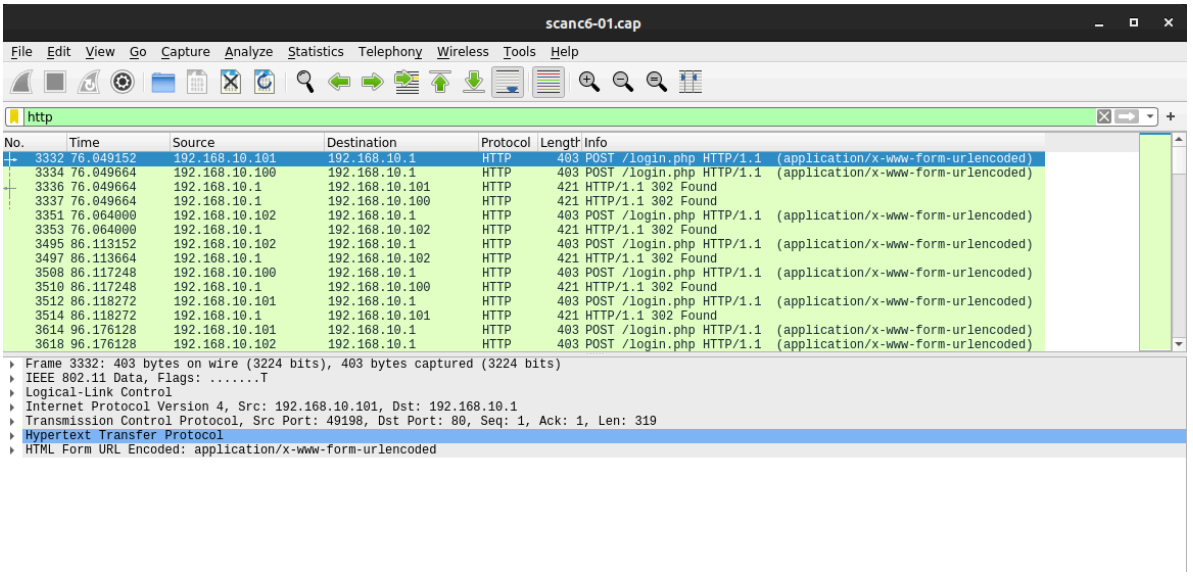
Una vez tenemos los handshakes y hemos obtenido la contraseña de la red podemos descifrar el tráfico utilizando Wireshark a través de la interfaz gráfica:

```
wireshark wifi/scanc6-01.cap
```



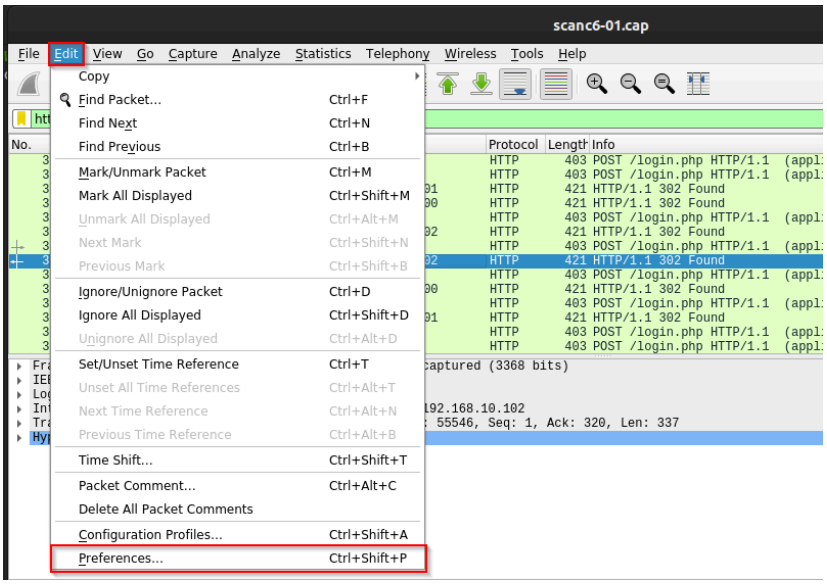
Wireshark de captura con handshakes

En este caso si filtramos por HTTP podemos ver el tráfico de la red abierta, por lo que no hay que confundirlos ya que en este método se muestra todo el tráfico, no solo el descifrado.



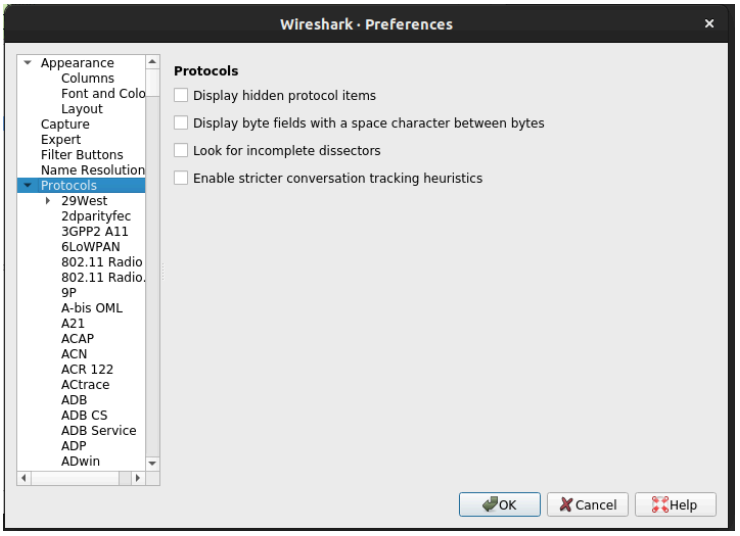
Filtrado inicial por HTTP con solo tráfico de redes OPN descifrado

Pero solo aparece información de la red 192.168.10.0/24, que es la red abierta. Por lo que temenos que poner la contraseña en la configuración de Wireshark para que descifre el tráfico. Para ello nos vamos a Edit → Preferences o Ctrl+Shift+P



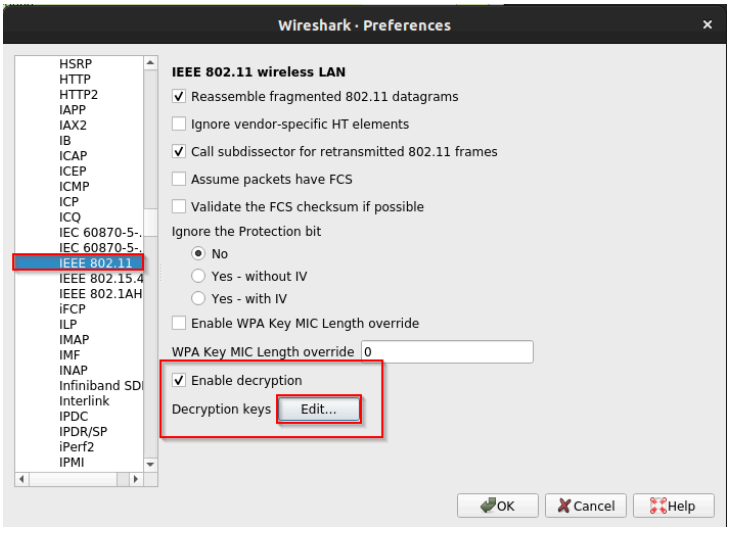
Preferencias en Wireshark

Y, en el apartado de protocolos buscamos IEEE 802.11:



Configuración de Protocolos en Wireshark

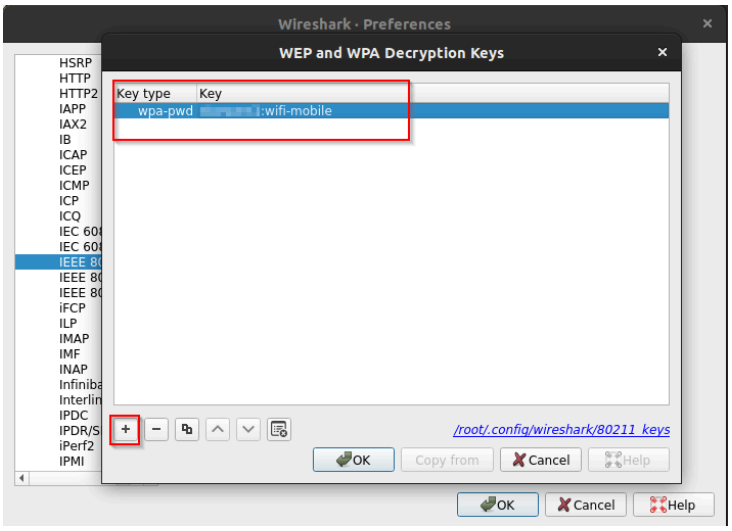
Verificamos que el check en Enable decryption está habilitado y pulsamos Edit.



Configuración de 802.11

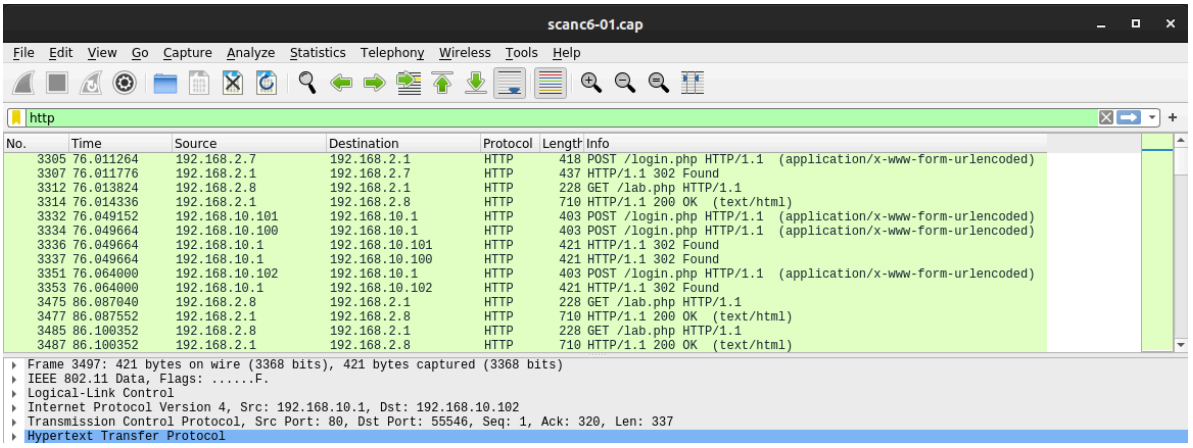
Aquí pulsamos el + y se nos crea una nueva entrada en la tabla. Para poner la contraseña en texto claro utilizamos el tipo wpa-pwd y en la key la contraseña en texto claro separada por dos puntos del ESSID.

Es posible poner únicamente la contraseña sin el ESSID, pero a veces da problemas.



Añadir información de descifrado PSK

Ahora si le damos a OK y podemos ver como aparece nueva información HTTP en la captura, en este caso de la red 192.168.2.1/24.



Trafico de red PSK descifrado

Optimización cracking de contraseñas

Cracking con GPU

El cracking de contraseñas utilizando GPUs (Unidades de Procesamiento Gráfico) es mucho más eficiente que métodos tradicionales que usan CPUs o tablas aircoiris (rainbow tables). Las GPUs están diseñadas para manejar operaciones paralelas masivas, lo que hace que pueden realizar una gran cantidad de cálculos hash simultáneamente.

Por qué es más eficiente el cracking con GPU utilizando hashcat:

- **Paralelización masiva**: Las GPUs tienen miles de núcleos que pueden procesar hashes en paralelo, aumentando significativamente la velocidad.
- **Velocidad de cálculo**: Las GPUs son mucho más rápidas en cálculos repetitivos, esenciales para el cracking de contraseñas.
- **Optimización de software**: Herramientas como hashcat están específicamente diseñadas para aprovechar la arquitectura de las GPUs.
- **Coste-eficiencia**: Aunque las GPUs pueden ser costosas, ofrecen una mejor relación costo/eficiencia en términos de hashes por segundo comparado con las CPUs.
- **Escalabilidad**: Hashcat puede usar múltiples GPUs en un solo sistema, aumentando la capacidad de cracking de manera eficiente.
- **Productividad mejorada**: El uso de GPUs reduce drásticamente el tiempo necesario para descifrar contraseñas, permitiendo evaluaciones más rápidas.

Comparativamente, las tablas rainbow son menos prácticas debido a su enorme requerimiento de espacio de almacenamiento y su falta de flexibilidad y escalabilidad para nuevas configuraciones o algoritmos hash. En conclusión, **crackear contraseñas con GPU** utilizando herramientas como hashcat es más rápido, práctico y escalable que otros métodos como el uso de CPUs o tablas rainbow.

Como alternativa a hashcat también se puede utilizar Pyrit (https://github.com/JPaulMora/Pyrit), que es capaz de crackear utilizando tanto CPU como GPU.

Ataques de Tablas Arcoíris (Rainbow Tables)

Los ataques de tablas arcoíris utilizan tablas precomputadas que contienen los valores hash de posibles contraseñas, reduciendo drásticamente el tiempo necesario para romper un PSK después de capturar el handshake de la red.

- **Explicación Técnica**: En lugar de calcular los valores hash en tiempo real (como con la fuerza bruta), las tablas arcoíris almacenan valores hash precomputados para combinaciones de SSIDs y posibles contraseñas. Cuando se captura un handshake, un atacante puede rápidamente comparar el hash del handshake capturado contra las entradas de la tabla.
- **Herramientas**: rainbowcrack y otras herramientas especializadas se utilizan para generar y utilizar tablas arcoíris para romper redes Wi-Fi.

Generación de Diccionarios Personalizados

Crear diccionarios personalizados adaptados a objetivos específicos puede mejorar significativamente la eficiencia del descifrado de PSK. Herramientas como CeWL ayudan a generar listas de palabras contextuales que aumentan las posibilidades de descubrir contraseñas legítimas.

```
cewl -d 2 -m 5 -w docswords.txt https://example.com
```

- -d 2 Esta opción especifica la profundidad de rastreo. En este caso, 2 indica que la herramienta seguirá los enlaces en el sitio web hasta dos niveles de profundidad.

- -m 5 Esta opción establece la longitud mínima de las palabras que se incluirán en la lista. Aquí, 5 significa que solo se recopilarán palabras que tengan al menos cinco caracteres.
- -w docswords.txt Esta opción indica el nombre del archivo donde se guardarán las palabras recopiladas. En este caso, las palabras se guardarán en un archivo llamado docswords.txt.
- https://example.com Esta es la URL del sitio web del cual CeWL extraerá las palabras.